תבנית מסמך הגדרת מאגר ושורת נוהל אירוע (אנגלית, המקור)

מסמך	תבנית מסמך הגדרת מאגר ושורת נוהל אירוע (אנגלית, המקור)
נתיב המקור	docs/privacy/en/05-database-definition-and-incident-line-template.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

נוסח אנגלי: המקור, והעברי (05) עוקב אחריו סעיף אחר סעיף. הנוסח העברי נמצא באותה תיקייה.

---

05 - Database definition document template and incident-procedure line

Status: TEMPLATE, DRAFT. Not legal advice. The organisation fills the `[BRACKETS]`; rows pre-filled from the code are facts verified against `origin/integ/290` @ `018795f96` (2026-10-19), cited as `B/` = `smplwise_vms/backend/smplwise/`. Whether the organisation needs such a document at all, what the law requires it to contain, whether the database must be registered, and which security level applies: **REQUIRES COUNSEL REVIEW (C4)**. The title "database definition document" (Hebrew: מסמך הגדרות מאגר) is used because the owner's decision of 2026-10-18 asked for it; no legal meaning is claimed for the name.

Part A - Database definition document (fill in, then counsel review)

#	Item	Content
1	Organisation (owner of the data)	[NAME, ID, ADDRESS] **REQUIRES COUNSEL REVIEW (C1)**
2	Person responsible for the database / privacy contact	[NAME, ROLE, CONTACT]
3	System	SmplWise Arx, version [VERSION], run as a Home Assistant add-on on [SERVER DESCRIPTION, LOCATION]. Supplier: SmplWise. Supplier access to the server: [YES/NO, HOW, WHEN] **REQUIRES COUNSEL REVIEW (C1)**
4	Storage	one local SQLite database `smplwise.db` and files in the add-on data directory (`B/config.py`); no SmplWise-operated copy in the code. Backups: `<data>/backups`, 5 pre-upgrade + 7 daily kept (`B/services/backup.py`); copies elsewhere: [WHERE / WHO / ENCRYPTED?] **REQUIRES COUNSEL REVIEW (C8)**
5	Purposes	[ORGANISATION DEFINES: building operation and security, service requests, vendor management, access control, staff accountability, ...]
6	Categories of information	choose from `01-data-processing-summary.md` section 2 (A-J); mark which are switched on at this site (tickets `tickets.enabled`; external door access `access.external_grants` is off and cannot be enabled in this build; phone presence `presence.*` off by default)

#	Item	Content
7	Categories of people	staff, vendors and their technicians, people who open service requests, [OTHERS]
8	Sources of information	typed by staff; typed by vendors on public pages; imported from Home Assistant (identity, devices); reported by the phone app; read from the door system and recorders
9	Recipients and outside services	table in `01-data-processing-summary.md` section 5, completed with [CONTRACTS / AGREEMENTS HELD] **REQUIRES COUNSEL REVIEW (C5, C6, C7)**
10	Transfers outside the country	[WHERE; basis] **REQUIRES COUNSEL REVIEW (C5, C6)**
11	Who may access, and how access is granted	roles and scoped permissions (`B/rbac.py`, `B/roles.json`, `docs/security/HA_IDENTITY_RBAC_HE.md`); list of current holders of `tickets.configure`, `access.external.grant`, `audit.read`, `backup.manage`, `system.configure`: [NAMES, review date]; permission reviews every [PERIOD]. Note: the host administrator can reach data outside Arx's access control (`docs/security/HA_IDENTITY_RBAC_HE.md` section 2)
12	Authentication	Home Assistant identity, or local accounts with scrypt/argon2id password hashes, optional passkeys and TOTP (`B/services/local_identity.py`, `B/services/local_passkeys.py`); session limits (`B/services/local_identity.py`)
13	Security measures in the code	access control, audit of writes, hashed tokens/sessions, rate limits, uniform failure responses on public pages, no personal code or phone number in audit rows or logs (`01-data-processing-summary.md` section 6; `docs/security/`). Organisational measures (physical access to the server, patching, backup protection): [ORGANISATION FILLS] **REQUIRES COUNSEL REVIEW (C4)**
14	Logging and monitoring	audit log (default 365 days, `audit.retention_days`); who reviews it and how often: [FILL]
15	Retention	the filled `06-retention-policy-template.md`
16	Handling people's requests	`03-data-subject-request-handling.md`, with named owner [NAME] **REQUIRES COUNSEL REVIEW (C11)**
17	Incident procedure	Part B
18	Review of this document	every [PERIOD] and on each change of purposes, recipients or system version; last review [DATE]

Part B - Incident-procedure line

A single line the organisation can place in its security procedure. The wording of the duties, who must be told, and by when are legal matters: **REQUIRES COUNSEL REVIEW (C12)**.

> **Incident line.** Anyone who notices or suspects that personal information handled through SmplWise Arx was lost, sent to the wrong person, or viewed or changed by someone not allowed to (including a lost phone with the app, a leaked link or entry code, or a stolen backup) tells [INCIDENT CONTACT, PHONE / E-MAIL] at once; [INCIDENT CONTACT] records the time, what happened and what was done, and decides with [COUNSEL / OFFICER] whether anyone else must be told and by when.

Technical steps the product offers once an incident is suspected (facts; the decision to use them is the organisation's):

- Revoke all external door access immediately: administrator action "revoke all" (`POST /access-grants/revoke-all`, confirmation word typed, audited as `access.grant.revoke_all`).
- Revoke one grant, or re-issue a code (`/access-grants/{id}/revoke`, `/rotate`; at most 3 sends per grant).
- Revoke a vendor or contact link (new link or deactivate the contact: live links are revoked at once, `B/services/tickets/contacts.py`).
- Revoke a phone-app device (`DELETE` of the device; token hash replaced, presence and push registration cleared, `B/services/presence.py`); the required-sensors policy can be suspended with a break-glass entry.
- Disable a local account or revoke its sessions; remove a user's remote access (`B/services/local_identity.py`, `B/routers/remote.py`).
- Evidence: the audit log (`audit.read`) and the grant attention notifications (content-free) point at what happened; backups are not a log.

What the product does not provide: automatic breach detection, an incident register, notification templates to authorities or individuals. **REQUIRES COUNSEL REVIEW (C12)**.